LAPORAN AUDIT KEAMANAN WEBSITE

Spencer Web Security Audit Tool

Target Website	sipadi-teknik.polmed.ac.id
URL Lengkap	https://sipadi-teknik.polmed.ac.id
Tanggal Audit	21 May 2026, 10:32:48 WIB
Metode	OWASP Top 10 + CVSS Scoring
Tool	SpencerWeb v2.0
Durasi Scan	414.91 detik

SECURITY GRADE: D **SKOR: 42/100**

1. RINGKASAN EKSEKUTIF

Audit keamanan website **sipadi-teknik.polmed.ac.id** telah dilakukan pada tanggal **21 May 2026, 10:32:48 WIB** menggunakan Spencer Web Security Audit Tool. Audit ini menggunakan metodologi OWASP Top 10 dengan sistem penilaian risiko CVSS yang disederhanakan menjadi grade A-F.

Berdasarkan 76 pengecekan keamanan yang dilakukan, sistem mendapat grade **D** dengan skor **42/100**. Ditemukan total **28 kerentanan** yang terdiri dari:

Severity	Jumlah	Dampak
CRITICAL	0	Risiko tertinggi, harus segera diperbaiki
HIGH	4	Risiko tinggi, perbaiki dalam waktu dekat
MEDIUM	2	Risiko sedang, jadwalkan perbaikan
LOW	22	Risiko rendah, perbaikan opsional

2. METODOLOGI AUDIT

Audit ini dilakukan menggunakan pendekatan **Black-box Testing** — auditor tidak memiliki akses ke source code maupun infrastruktur internal, dan hanya berinteraksi dengan target sebagaimana attacker dari luar.

Framework yang digunakan:
• **OWASP Top 10** — standar industri untuk web application security testing
• **OWASP Testing Guide v4** — panduan teknis pengujian per kategori
• **CVSS v3.1** — Common Vulnerability Scoring System untuk penilaian risiko

Module yang dijalankan:
1. HTTP Security Headers Audit (Passive)
2. SSL/TLS Certificate Audit (Passive)
3. Sensitive File Exposure Scan (Passive)
4. CMS Detection & Version Check (Passive)
5. WordPress Plugin & Theme Scanner (Passive)
6. SQL Injection Scanner — Error, Boolean, Time-based (Active)
7. Reflected XSS Scanner (Active)
8. Stored XSS Scanner (Active)
9. CSRF Protection Checker (Active)
10. Open Port Reconnaissance (Active)

3. TEMUAN KERENTANAN

Temuan #1: Content-Security-Policy	HIGH
Deskripsi:	Mencegah XSS dan injeksi konten berbahaya
Rekomendasi:	Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

Temuan #2: CSRF: POST form → /login/forgot_password.php	HIGH
Deskripsi:	Form POST tanpa CSRF token — rentan terhadap CSRF attack
Rekomendasi:	Tambahkan CSRF token (hidden input) pada setiap form POST. Gunakan framework yang mendukung CSRF protection built-in (Django, Laravel, Express csrf middleware).

Temuan #3: HTTP Method: PUT	HIGH
Deskripsi:	PUT method diterima server (HTTP 200) — File upload/overwrite — attacker bisa upload webshell atau overwrite file
Rekomendasi:	Disable PUT method kecuali diperlukan untuk API (dan lindungi dengan autentikasi)

Temuan #4: HTTP Method: DELETE	HIGH
Deskripsi:	DELETE method diterima server (HTTP 200) — File deletion — attacker bisa menghapus file di server
Rekomendasi:	Disable DELETE method kecuali diperlukan untuk API

Temuan #5: X-Content-Type-Options	MEDIUM
Deskripsi:	Mencegah MIME-type sniffing
Rekomendasi:	Tambahkan header: X-Content-Type-Options: nosniff

Temuan #6: Cookie: MoodleSession (session)	MEDIUM
Deskripsi:	Cookie 'MoodleSession' memiliki 1 masalah: SameSite=Missing
Rekomendasi:	Set flag: SameSite=Lax pada cookie 'MoodleSession'

Temuan #7: X-XSS-Protection	LOW
Deskripsi:	Mengaktifkan filter XSS bawaan browser (legacy)
Rekomendasi:	Tambahkan header: X-XSS-Protection: 1; mode=block (atau gunakan CSP sebagai pengganti)

Temuan #8: Referrer-Policy	LOW
Deskripsi:	Mengontrol informasi referrer yang dikirim browser
Rekomendasi:	Tambahkan header: Referrer-Policy: strict-origin-when-cross-origin

Temuan #9: Permissions-Policy	LOW
Deskripsi:	Mengontrol akses fitur browser (kamera, mikrofon, geolokasi)
Rekomendasi:	Tambahkan header: Permissions-Policy: geolocation=(), camera=(), microphone=()

Temuan #10: Server (Info Leak)	LOW
Deskripsi:	Terdeteksi: cloudflare — Membocorkan versi web server (misal: Apache/2.4.41)
Rekomendasi:	Sembunyikan atau hapus header Server dari response

Temuan #11: File: /package.json	LOW
Deskripsi:	EXPOSED! Node.js package.json exposed — membocorkan dependensi & versi (HTTP 200, 1825 bytes)
Rekomendasi:	Blokir akses ke package.json via web server

Temuan #12: File: /composer.json	LOW
Deskripsi:	EXPOSED! PHP Composer config exposed — membocorkan dependensi (HTTP 200, 2094 bytes)
Rekomendasi:	Blokir akses ke composer.json

Temuan #13: Info Leak: Email Address [/]	LOW
Deskripsi:	Email address ditemukan di source code — bisa digunakan untuk phishing/spam. Value (masked): sipa****c.id
Rekomendasi:	Jangan hardcode email di HTML. Gunakan form kontak atau obfuscation.

Temuan #14: Directory: /login	LOW
Deskripsi:	Path /login accessible (HTTP 301, 341 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #15: Directory: /auth	LOW
Deskripsi:	Path /auth accessible (HTTP 301, 340 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #16: Directory: /admin	LOW
Deskripsi:	Path /admin accessible (HTTP 301, 341 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #17: Directory: /config.php	LOW
Deskripsi:	Path /config.php accessible (HTTP 200, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #18: Directory: /backup	LOW
Deskripsi:	Path /backup accessible (HTTP 301, 342 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #19: Directory: /composer.json	LOW
Deskripsi:	Path /composer.json accessible (HTTP 200, 2094 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #20: Directory: /README.md	LOW
Deskripsi:	Path /README.md accessible (HTTP 200, 1894 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #21: Directory: /README	LOW
Deskripsi:	Path /README accessible (HTTP 200, 1894 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #22: Directory: /package.json	LOW
Deskripsi:	Path /package.json accessible (HTTP 200, 1825 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #23: Directory: /composer.lock	LOW
Deskripsi:	Path /composer.lock accessible (HTTP 200, 168233 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #24: Directory: /robots.txt	LOW
Deskripsi:	Path /robots.txt accessible (HTTP 200, 26 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #25: Directory: /security.txt	LOW
Deskripsi:	Path /security.txt accessible (HTTP 200, 670 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #26: Directory: /install	LOW
Deskripsi:	Path /install accessible (HTTP 301, 343 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #27: Directory: /install.php	LOW
Deskripsi:	Path /install.php accessible (HTTP 302, 0 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

Temuan #28: Directory: /.github	LOW
Deskripsi:	Path /.github accessible (HTTP 301, 343 bytes)
Rekomendasi:	Verifikasi apakah path ini perlu accessible publik. Blokir jika tidak diperlukan.

4. DETAIL HASIL PER MODULE

Module 1 — HTTP Security Headers

Passed: **5** | Failed: **6** | Total: **11**

Check	Severity
Content-Security-Policy	HIGH
X-Content-Type-Options	MEDIUM
X-XSS-Protection	LOW
Referrer-Policy	LOW
Permissions-Policy	LOW
Server (Info Leak)	LOW

Module 2 — SSL/TLS Certificate

Passed: **6** | Failed: **0** | Total: **6**

Module 3 — Sensitive File Exposure

Passed: **33** | Failed: **2** | Total: **35**

Check	Severity
File: /package.json	LOW
File: /composer.json	LOW

Module 4 — CMS Detection

Passed: **1** | Failed: **0** | Total: **1**

Module 6 — Advanced SQL Injection

Passed: **1** | Failed: **0** | Total: **1**

Module 7 — Reflected XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 8 — Stored XSS

Passed: **1** | Failed: **0** | Total: **1**

Module 9 — CSRF Protection

Passed: **6** | Failed: **1** | Total: **7**

Check	Severity
CSRF: POST form → /login/forgot_password.php	HIGH

Module 10 — Port Reconnaissance

Passed: **4** | Failed: **0** | Total: **4**

5. KESIMPULAN DAN SARAN PRIORITAS

Berdasarkan hasil audit, website **sipadi-teknik.polmed.ac.id** memiliki **0 kerentanan CRITICAL** dan **4 kerentanan HIGH** yang memerlukan perhatian segera.

Saran prioritas perbaikan:

1. [HIGH] Content-Security-Policy
Tambahkan header CSP yang sesuai. Minimal: Content-Security-Policy: default-src 'self'

2. [HIGH] CSRF: POST form → /login/forgot_password.php
Tambahkan CSRF token (hidden input) pada setiap form POST. Gunakan framework yang mendukung CSRF protection built-in (Django, Laravel, Express csrf middleware).

3. [HIGH] HTTP Method: PUT
Disable PUT method kecuali diperlukan untuk API (dan lindungi dengan autentikasi)

4. [HIGH] HTTP Method: DELETE
Disable DELETE method kecuali diperlukan untuk API

5. [MEDIUM] X-Content-Type-Options
Tambahkan header: X-Content-Type-Options: nosniff

DISCLAIMER

Laporan ini dihasilkan secara otomatis oleh Spencer Web Security Audit Tool. Audit dilakukan pada waktu dan kondisi tertentu; kondisi keamanan website dapat berubah seiring waktu. Hasil audit ini hanya mencakup parameter yang diuji oleh tool dan tidak menggantikan audit keamanan manual oleh professional security expert. Beberapa temuan automated scanner dapat berupa false positive dan harus diverifikasi secara manual sebelum tindakan perbaikan diambil.

Generated by Spencer v2.0 — 21 May 2026